FarmaExpres

Historia de Usuario

HU-RF-02 - Autenticación (Inicio de sesión)

Código	HU-RF-02
Módulo	Seguridad y Gestión de Usuarios
Versión	1.0
Fecha	2026-03-03

1. Resumen

Esta historia de usuario describe el proceso de autenticación del sistema, permitiendo que un usuario ingrese con credenciales válidas para obtener un token de sesión. El sistema debe registrar en bitácora tanto los inicios de sesión exitosos como los fallidos y aplicar control de sesiones activas.

2. Información de la historia de usuario

Campo	Detalle
ID	HU-RF-02
Nombre	Autenticación (Inicio de sesión)
Actor principal	Usuario del sistema
Actores secundarios	Administrador (para auditoría en bitácora)
Objetivo	Permitir el acceso seguro al sistema mediante credenciales y emisión de token.
Dependencias	RF-01 Registro/gestión de usuarios (existencia de credenciales).
Prioridad	Alta
Frecuencia	Alta (uso diario)

3. Alcance

- Incluye: validación de credenciales, generación y entrega de token, registro en bitácora, control de sesiones activas.
- No incluye: recuperación de contraseña, cambio de contraseña, gestión de roles (se trata en otras historias).

4. Precondiciones

- El usuario debe estar previamente registrado en el sistema y contar con credenciales (usuario/correo y contraseña).
- El sistema debe tener habilitado el módulo de bitácora para registrar intentos de inicio de sesión.
- Para auditoría: un administrador debe poder consultar la bitácora usando un token válido.

5. Entradas y salidas

Campo	Detalle
Entradas	Usuario/correo y contraseña.
Salida exitosa	Token de autenticación (p. ej., JWT o equivalente) y estado de sesión activa.
Salida fallida	Mensaje de error y código 403 (credenciales inválidas).

6. Reglas de negocio y validaciones

1. El sistema debe validar que las credenciales correspondan a un usuario existente.
2. Si las credenciales son correctas, el sistema debe generar un token y devolverlo al usuario.
3. Si las credenciales son incorrectas, el sistema debe responder con un mensaje de error y código 403.
4. Cada intento de autenticación (exitoso o fallido) debe registrarse en bitácora con fecha/hora y usuario.
5. El sistema debe aplicar control de sesiones activas (por ejemplo, registrar sesión activa y evitar inconsistencias).

7. Flujo principal

6. El usuario ingresa su usuario/correo y contraseña en la pantalla de inicio de sesión.
7. El sistema valida las credenciales contra los registros existentes.
8. Si las credenciales son válidas, el sistema genera el token de autenticación.
9. El sistema registra en bitácora el inicio de sesión exitoso.
10. El sistema responde con el token para que el usuario pueda operar en el sistema.

8. Flujos alternos y excepciones

8.1 Credenciales inválidas

11. El usuario ingresa credenciales incorrectas.
12. El sistema rechaza la autenticación y retorna un mensaje de error con código 403.
13. El sistema registra en bitácora el intento de inicio de sesión fallido.

9. Postcondiciones

- Si es exitoso: el usuario queda autenticado con un token activo y su sesión queda registrada.
- Si es fallido: el usuario no obtiene token y el intento queda registrado en bitácora.

10. Criterios de aceptación

☐ Validar credenciales.

☐ Cuando las credenciales estén correctas, generar el token.

☐ Mostrar mensaje en caso de error.

☐ Retornar código 403 cuando las credenciales sean incorrectas.

☐ Registrar intento (exitoso o fallido) en bitácora.

☐ Aplicar control de sesiones activas.

☐ Con el token de un administrador autenticado, poder verificar en bitácora el login fallido.

☐ Con el token de un administrador autenticado, poder verificar en bitácora el login exitoso.

11. Evidencias de prueba

A continuación se presentan evidencias reales de las pruebas realizadas (API/bitácora), con una breve explicación de lo que valida cada captura.

Comentario: Login exitoso: el sistema valida credenciales correctas y responde 200 OK, devolviendo un token (JWT) para consumir endpoints protegidos.

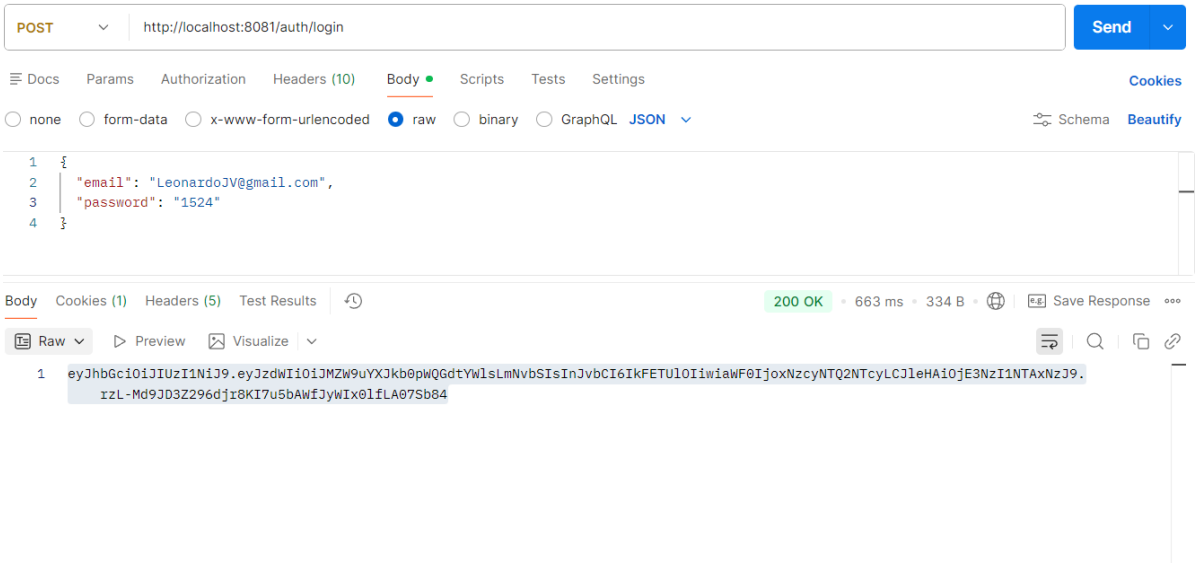

Figura 1. Autenticación exitosa (token generado).

Comentario: Login fallido: al enviar credenciales incorrectas, el sistema rechaza el acceso y responde con código 403 (Forbidden).

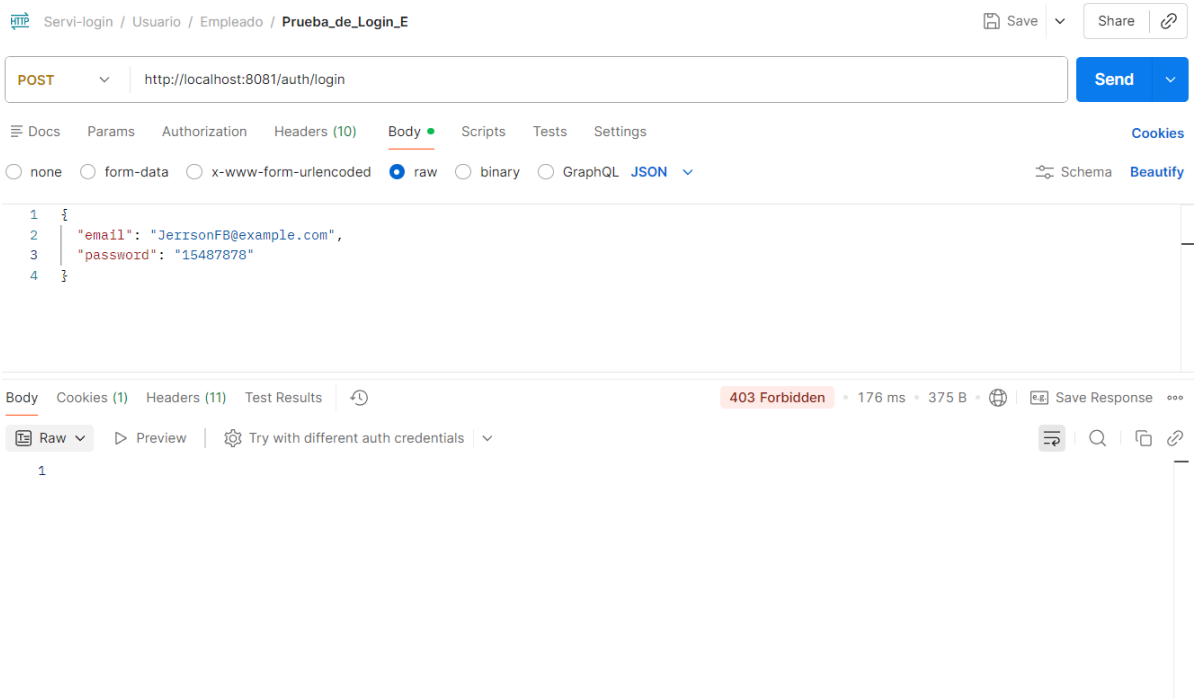

Figura 2. Autenticación fallida (403 por credenciales inválidas).

Comentario: Bitácora: usando un token de administrador, se consulta el historial y se observa el registro de intentos de login (exitoso y fallido).

Servi-login / Usuario / Admin / **Bitacora**

Save | Share

GET http://localhost:8081/bitacora Send

Docs | Params | Authorization | Headers (9) | Body | Scripts | Tests | Settings | Cookies

Auth Type: Be...

Token: ••••••••••••••••••••••••••••••••

The authorization header will be automatically generated when you send the request. Learn more about Bearer Token authorization.

Body | Cookies (1) | Headers (11) | Test Results — 200 OK · 14 ms · 1.23 KB · Save Response

{} JSON | Preview | Visualize


```
        "fechaHora": "2026-03-03T08:58:40.233091",
        "id": 12
    },
    {
        "usuarioId": 1,
        "accion": "LOGIN_EXITOSO",
        "fechaHora": "2026-03-03T09:02:52.471659",
        "id": 13
    },
    {
        "usuarioId": 3,
        "accion": "LOGIN_FALLIDO - JerrsonFB@example.com",
        "fechaHora": "2026-03-03T09:03:07.270267",
        "id": 14
    }
]
```


Figura 3. Registro en bitácora de autenticación exitosa y fallida.

Comentario: Token de administrador: evidencia adicional de generación de token para un usuario con rol ADMIN (utilizado para verificaciones de auditoría).

Servi-login / Usuario / Admin / **Prueba_de_Login_A**

Save | Share

POST http://localhost:8081/auth/login Send

Docs | Params | Authorization | Headers (10) | Body | Scripts | Tests | Settings | Cookies

none | form-data | x-www-form-urlencoded | raw | binary | GraphQL | JSON — Schema | Beautify


```
{
  "email": "LeonardoJV@gmail.com",
  "password": "1524"
}
```


Body | Cookies (1) | Headers (5) | Test Results — 200 OK · 675 ms · 334 B · Save Response

Raw | Preview | Visualize


```
eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJMZW9uYXJkb0pWQGdtYWlsLmNvbSIsInJvbCI6IkFETUlOIiwiaWF0IjoxNzcyNTQ1NzQxLCJleHAiOjE3NzI1NDkzNDF9.
NjlATnHj_sOQtYwTB9PEYT_TfYPQwEJsb_TyKD18Eww
```

Figura 4. Token de administrador para consultas de auditoría.

12. Casos de prueba sugeridos

12.1 Login exitoso

- Pasos: ingresar credenciales válidas -> enviar.
- Resultado esperado: el sistema retorna token y registra 'login exitoso' en bitácora.
- Verificación: con token de administrador, consultar bitácora y confirmar el registro.

12.2 Login fallido

- Pasos: ingresar credenciales inválidas -> enviar.
- Resultado esperado: el sistema retorna mensaje de error con código 403 y registra 'login fallido' en bitácora.
- Verificación: con token de administrador, consultar bitácora y confirmar el registro.